

THREAT ANALYSIS REPORT

Classification: TLP:AMBER | TR-2024-0615-001

Security Research Team | June 15, 2024

THREAT ANALYSIS REPORT

=====
Classification: TLP:AMBER
Date: 2024-06-15
Analyst: Security Research Team
Reference: TR-2024-0615-001

EXECUTIVE SUMMARY

This report details a sophisticated cyber espionage campaign attributed to the APT29 threat group (also tracked as Cozy Bear, Midnight Blizzard, and NOBELIUM), targeting government agencies and technology companies across North America and Europe. The campaign, observed between January and June 2024, utilizes a multi-stage infection chain combining spear-phishing, custom malware loaders, and novel C2 infrastructure.

The threat actors leveraged CVE-2023-23397 (Microsoft Outlook privilege escalation) and CVE-2024-21413 (Microsoft Outlook remote code execution) as initial access vectors, followed by deployment of previously undocumented malware tracked as ENVYSCOUT and HALFRIG.

TECHNICAL ANALYSIS

Initial Access (TA0001):
Attackers sent targeted phishing emails containing malicious .RDP files to high-value targets within government ministries and diplomatic entities. The RDP files, when opened, established connections to actor-controlled infrastructure, enabling credential harvesting and file system access.

Observed Techniques:
- T1566.001: Spearphishing Attachment
- T1566.002: Spearphishing Link
- T1190: Exploit Public-Facing Application
- T1078.004: Cloud Accounts

Execution (TA0002):
Post-compromise, the actors deployed PowerShell scripts and leveraged WMI for lateral movement and data collection.

Observed Techniques:
- T1059.001: PowerShell
- T1047: Windows Management Instrumentation
- T1204.002: Malicious File

Persistence (TA0003):
The group established persistence through registry Run keys and OAuth application abuse in compromised Microsoft 365 tenants.

Observed Techniques:

- T1547.001: Registry Run Keys / Startup Folder
- T1098: Account Manipulation
- T1136: Create Account

Defense Evasion (TA0005):

Actors employed Golden SAML techniques and disabled endpoint security tools to evade detection.

Observed Techniques:

- T1550: Use Alternate Authentication Material
- T1562.001: Disable or Modify Tools
- T1656: Impersonation

Command and Control (TA0011):

C2 communications were routed through residential proxy networks and compromised VPN appliances. Notably, the group used the Notion API as a novel C2 channel to blend with legitimate traffic.

Observed Techniques:

- T1090.002: External Proxy
- T1573: Encrypted Channel

INDICATORS OF COMPROMISE (IOCs)

Network Indicators:

IP Addresses:

185.172.39.50 - Primary C2 server (Hetzner, Germany)
185.216.72.182 - Secondary C2 fallback (Hetzner, Germany)
151.236.14.116 - Credential harvesting server (Edgio, Netherlands)
178.239.171.41 - Phishing redirector (BuyVM, Luxembourg)
135.181.130.232 - Reconnaissance scanner (OVH, France)
141.195.117.125 - Malware staging server (DataWagon, US)
142.91.38.80 - VPN exit node used for operational relay
149.154.158.133 - Additional C2 infrastructure

Domains:

waterforvoiceless.org - Spear-phishing landing page
siestakeying.com - C2 redirector domain
mail-security-check.net - Credential harvesting portal
auth-update-server.com - Malware download server
0x3bd487.open - Staging domain for second-stage payloads

URLs:

<https://waterforvoiceless.org/invite.php> - Phishing page
<https://siestakeying.com/auth.php> - C2 authentication endpoint
<https://mail-security-check.net/verify/login> - Credential capture
<http://auth-update-server.com/download/update.exe> - Payload delivery
<https://0x3bd487.open/delivery> - Second-stage loader

File Hashes:

ENVYSCOUT Loader (initial phishing attachment):

MD5: 5b1c3d4e5f6a7b8c9d0e1f2a3b4c5d6e
SHA1: 395da6d4f3c890295f7584132ea73d759bd9d094
SHA256: a0f183ea54cb25dd8bdba586935a258f0ecd3cba0d94657985bb1ea02af8d42c

HALFRIG Dropper (second stage):

MD5: d41d8cd98f00b204e9800998ecf8427e

SHA1: da39a3ee5e6b4b0d3255bfef95601890afd80709
SHA256: 2cf24dba5fb0a30e26e83b2ac5b9e29e1b161e5c1fa7425e73043362938b9824

Vulnerabilities Exploited:
CVE-2023-23397 - Microsoft Outlook EoP (CVSS 9.8)
CVE-2024-21413 - Microsoft Outlook RCE (CVSS 9.8)
CVE-2022-27924 - Zimbra Command Injection (CVSS 7.5)
CVE-2023-42793 - TeamCity Authentication Bypass (CVSS 9.8)

ATtribution

This campaign is attributed to APT29 (also known as Cozy Bear, Midnight Blizzard, NOBELIUM, The Dukes, UNC2452) with HIGH confidence based on:

- 1. TTP overlap with previous SVR-attributed operations
- 2. Infrastructure patterns matching known APT29 operational infrastructure
- 3. Targeting profile consistent with Russian foreign intelligence priorities
- 4. Use of custom malware families (ENVYSCOUT, HALFRIG) unique to this group

Mitigation Recommendations

- 1. Apply security updates for CVE-2023-23397, CVE-2024-21413, CVE-2022-27924, and CVE-2023-42793 immediately
- 2. Block all IP addresses and domains listed in the IOCs section at network perimeter firewalls and web proxies
- 3. Deploy MFA using FIDO2 hardware tokens for all privileged accounts
- 4. Monitor OAuth application consent grants in Microsoft 365 tenants
- 5. Implement application control to block execution of untrusted executables
- 6. Deploy EDR solutions with detection rules for the listed IOCs
- 7. Conduct threat hunting exercises using the ATT&CK techniques listed above

Appendix A: YARA Rules

```
rule APT29_ENVYSCOUT_Loader {
  strings:
    $s1 = "waterforvoiceless.org" nocase wide ascii
    $s2 = "/invite.php" nocase ascii
    $s3 = { 48 83 EC 28 48 8B 05 [4] 48 85 C0 74 }
  condition:
    uint16(0) == 0x5A4D and 2 of them
}
```

Contact: threat-intel@security-research.example.com
SHA256 of this report: 7f83b1657ff1fc53b92dc18148a1d65dfc2d4b1fa3d677284addd200126d9069